

中华人民共和国通信行业标准

YD/T XXXXX—XXXX

电信网和互联网网络安全能力成熟度评价
模型

Maturity assessment model for cybersecurity capability of telecom network and
Internet

(点击此处添加与国际标准一致性程度的标识)

(报批稿)

XXXX – XX – XX 发布

XXXX – XX – XX 实施

中华人民共和国工业和信息化部 发布

目 次

前 言	3
1 范围	4
2 规范性引用文件	4
3 术语和定义	4
4 概述	4
4.1 能力成熟度评价	4
4.2 能力成熟度评价模型	4
5 能力域	5
5.1 制度管理	5
5.1.1 网络安全规划	6
5.1.2 网络安全管理制度	6
5.2 组织和人员管理	7
5.2.1 组织机构及人员岗位	7
5.2.2 人力资源管理	8
5.2.3 教育培训及考核	9
5.2.4 沟通与合作	9
5.3 资产管理	10
5.3.1 资产清单管理	10
5.3.2 资产日常管理和维护	11
5.3.3 资产变更管理	12
5.4 风险管理	13
5.4.1 风险控制	13
5.4.2 风险识别和防范	13
5.5 供应链安全管理	14
5.5.1 供应链安全风险管理的	14
5.5.2 采购情况管理	14
5.6 系统和通信防护	15
5.6.1 身份管理	15
5.6.2 访问控制	16
5.6.3 系统和边界防护	17
5.7 运行维护	18
5.7.1 安全运维	18
5.7.2 状态监控	18
5.7.3 日志及审计	19
5.7.4 备份和恢复	20
5.8 检测评估	20
5.9 安全态势分析	21
5.9.1 漏洞管理	21
5.9.2 威胁信息管理	22

5.9.3 态势感知	23
5.10 网络安全事件管理	24
5.10.1 事件响应和处置	24
5.10.2 应急演练	25
参 考 文 献	26

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、中国移动通信集团有限公司、中国联合网络通信集团有限公司、华为技术有限公司、中电科网络空间安全研究院有限公司、上海观安信息技术股份有限公司、北京长亭未来科技有限公司、北京天融信网络安全技术有限公司、杭州安恒信息技术股份有限公司、北京神州绿盟科技有限公司、北京经纬信安科技有限公司、哈尔滨工业大学（威海）、长扬科技（北京）股份有限公司、OPPO广东移动通信有限公司、中电信数智科技有限公司、江苏易安联网络技术有限公司、中孚信息股份有限公司、中移（杭州）信息技术有限公司、中兴通讯股份有限公司、北京奇虎科技有限公司。

本文件主要起草人：孟楠、赵泰、蒋敏慧、张思齐、赵爽、董骅、董航、孙念、李海明、邱勤、王娜、蒋武、王西子、谢江、吴绍柳、张静、梁伟、欧阳周婷、于磊、王佰玲、汪义舟、李根、徐赵虎、于振伟、张振山、程晋雪、周继华、姚一楠。

电信网和互联网网络安全能力成熟度评价模型

1 范围

本文件规定了电信网和互联网网络安全能力成熟度模型的构成、等级划分标准、关键能力域和成熟度要求。

本文件适用于指导电信网和互联网网络运营者和第三方安全评价机构开展电信网和互联网网络安全能力评价活动，也适用于运营者开展网络安全能力建设及电信管理机构实施监督管理。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 5271.8-2001 信息技术 词汇 第8部分：安全

3 术语和定义

GB/T 5271.8-2001界定的以及下列术语和定义适用于本文件。

3.1

能力成熟度模型 capability maturity model

评价各项实践、过程和方法当前能力水平，并提出改进目标及优先级的一种指标体系。

4 概述

4.1 能力成熟度评价

电信网和互联网网络安全能力成熟度评价的评价对象为电信网和互联网网络运营者（如基础电信企业集团二级部门、省公司，行业关键信息基础设施运营者、大型互联网企业等），通过对运营者建设、运维电信网和互联网网络安全关键能力进行量化分析，科学评价运营者网络安全防护各项实践、过程和方法当前的能力水平，提出改进目标、优先级及相关举措。

4.2 能力成熟度评价模型

网络安全能力成熟度评价模型包括能力成熟度等级、网络安全关键能力域、网络安全管理生命周期3个维度，如图1所示。

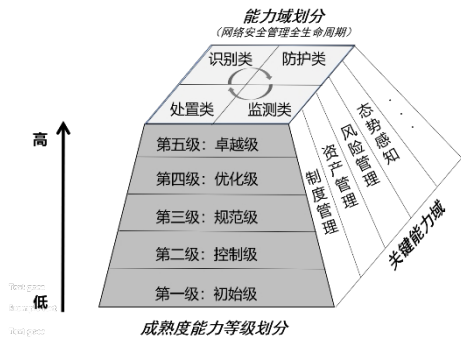


图1 网络安全能力成熟度评价模型

能力成熟度评价将覆盖网络安全管理全生命周期，贯穿识别、防护、监测、处置各阶段，形成闭环。

电信网和互联网网络安全能力成熟度评价要素包括10个网络安全关键能力域，其中制度管理、组织和人员管理、资产管理、风险管理、供应链管理等属于识别过程域，系统和通信防护、运行维护、检测评估安全防护类过程域，态势感知、网络安全事件管理等属于监测、处置类过程域。通过量化评价能力域及具体的评价指标，开展网络安全能力成熟度评价。

电信网和互联网网络安全能力成熟度等级即电信网和互联网安全防护能力的不同发展阶段，能力成熟度等级分为五级，自低向高依次为初始级、控制级、规范级、优化级、卓越级，每个成熟度级别为运营者网络安全防护能力所达到的水平，如表1所示。

表1 能力成熟度等级特征描述

成熟度等级	等级特征	关键词描述
五级：卓越级	具有成熟完善的网络安全管理体系与相应实践能力,实现数字化、智能化,并在此基础上持续跟踪业界新技术架构发展演进情况、主动探索实践，实现网络安全能力持续提升，引领带动行业网络安全能力发展趋势。	智能、深度、创新引领
四级：优化级	具有应对较大网络安全威胁,处理相对复杂网络安全事件的能力，引入自动化机制，持续优化调整网络安全工作体系和文档规程，并能够根据实际情况动态灵活调整。	积极、定期、持续更新
三级：规范级	具有应对一般和部分较大网络安全威胁的能力，已形成体系化、规范化的文档规程作为工作指导，定期主动开展安全检查。	充分、体系化、制度化
二级：控制级	具有应对一般安全威胁，处理一般性网络安全相关管理任务的能力，初步建立部分文档化规程体系作为工作指导。	主动、部分、文档化
一级：初始级	具有应对部分一般网络安全威胁，处理随机性、简易性网络安全管理相关任务的能力。	被动、随机、临时性

成熟度等级在每个能力域是累积的。为了在给定能力域获得某成熟度等级，运营者必须满足该级别及其前面级别的所有要求，例如，运营者必须满足某能力域中成熟度一级和成熟度二级所有要求，才能获得该能力域成熟度二级的判定。

5 能力域

5.1 制度管理

5.1.1 网络安全规划

5.1.1.1 初始级

应根据临时需求或基于个人经验，有临时、部分的或者非正式的网络安全工作计划。

5.1.1.2 控制级

应制定专门的网络安全工作计划，有具备适当权限的管理人员为网络安全工作计划提供支持。

5.1.1.3 规范级

本级要求包括：

- a) 应建立并维护中长期网络安全战略规划，与业务发展目标有机结合，明确定义网络安全工作的目标、主要活动、遵循的标准和指南，包括但不限于架构建设、制度建设、平台建设、技术研发等；
- b) 应结合业务特点和网络安全现状，制定年度安全工作计划，明确本年度网络安全工作重点方向和实施细则，并确保各项计划分配给具体的部门及人员负责；
- c) 应落实网络安全三同步要求，提供必要的人力、资金和技术资源。

5.1.1.4 优化级

本级要求包括：

- a) 应定期组织审定网络安全规划，并依据政策要求以及业务和环境变化、安全风险评估、安全态势感知、安全事件处置等结果，持续改进工作规划；
- b) 应组织相关部门、安全专家、专业技术服务机构对网络安全规划的合理性和正确性进行论证的审定；
- c) 应指定专门的部门或者人员负责持续监控网络安全计划执行情况，强化实施监督落实；
- d) 应制定网络安全能力提升方案，纳入战略规划和年度计划并落实；
- e) 应采取测试、评审、桌面推演等多种形式，对网络安全规划、建设、运行等阶段拟采取的安全措施进行验证；
- f) 应建立促进企业网络安全保障能力持续优化的长效机制，有效激励网络安全技术创新，促进网络安全架构升级。

5.1.1.5 卓越级

本级要求包括：

- a) 应组织专家团队跟踪和评估网络安全工作计划中各项任务实施的有效性，评估各项任务对于企业安全能力提升的作用；
- b) 应持续跟踪国内外政策环境、技术演进、威胁进化、产业发展情况，及时评估网络安全战略规划，实现动态调整优化，明确后续网络安全能力提升方向。

5.1.2 网络安全管理制度

5.1.2.1 初始级

应制定临时性的网络安全指南规程，满足内部的、监管方面的以及客户提出的安全要求。

5.1.2.2 控制级

本级要求包括：

- a) 应根据业务特性和外部合规要求，对核心业务和关键资产、工作流程进行管理制度建设，如网络安全管理要求、操作规程等；
- b) 应指定专人负责网络安全管理制度的管理工作；
- c) 应确定基本的网络安全原则，如最少功能、默认拒绝、最少特权等。

5.1.2.3 规范级

本级要求包括：

- a) 应制定体系化的安全管理制度体系，由管理制度、安全配置策略、安全操作规程和记录表单附件等构成；
- b) 应建立完善的网络安全管理制度，包括但不限于物理安全管理制度、风险管理制度、系统建设安全管理制度、系统运维安全管理制度、数据安全管理制度、人员安全管理制度、网络安全教育和培训管理制度、容灾备份和恢复管理制度、供应链安全管理制度等制度规范；
- c) 应识别法律法规、部门规章、规范性文件以及国家标准、行业标准等涉及自身业务或系统的强制性要求，完善安全管理制度体系予以落实；
- d) 应建立制度体系的制订、评审、发布、变更、保存及废止流程；明确制度文件发布范围，确保发布到各级相关人员；
- e) 应建立管理层评审机制，参与制度体系评审，并负责最终审批发布。

5.1.2.4 优化级

本级要求包括：

- a) 应定期组织审定网络安全管理制度体系，并根据政策标准制定、安全风险和威胁相关情况进行内容修订；
- b) 应记录并定期评价网络安全规划和安全管理制度的实施情况和实施效果，形成评价报告，包括但不限于评估有关要求实施的符合性和有效性、资源配置的合理性；并根据评价结果持续完善网络安全规划和安全管理制度。

5.1.2.5 卓越级

应建立贯穿明确目标、制修订制度、组织实施、认清差距、反馈优化的闭环管理工作机制，确保管理制度动态适配外部情况、运营者现状。

5.2 组织和人员管理

5.2.1 组织机构及人员岗位

5.2.1.1 初始级

应以临时或者非正式的方式将网络安全责任分配给特定人员。

5.2.1.2 控制级

本级要求包括：

- a) 应设置系统管理员、审计管理员、安全管理员等网络安全相关岗位，建立岗位人员清单列表；
- b) 应确保岗位职能设置满足权责分离。

5.2.1.3 规范级

本级要求包括：

- a) 应在运营者内部正式建立网络安全专机构及专职岗位，明确机构与岗位职责；
- b) 应具有具备网络安全统筹规划能力的个人或团队（成立网络安全委员会或领导小组，组织主要负责人担任领导职务指导和管理网络安全工作，设立首席网络安全官等）；
- c) 应建立组织内涉及网络安全相关职能的各部门间协作关系及联动机制；
- d) 应制定授权和审批相关制度，明确各部门、各岗位审批事项范围及审批流程，针对具体操作执行保留授权审批记录；
- e) 应以在线平台等内部公开、可查询的形式，公布组织内网络安全相关职能部门组织架构及人员联系方式。

5.2.1.4 优化级

本级要求包括：

- a) 应基于运营者最新网络安全方针及策略，定期评估组织架构中网络安全相关岗位划分与岗位数量总体占比等因素，确定是否满足规划发展需求；
- b) 应定期对现有网络安全岗位职责和工作要求及其实际运行情况进行评估，根据结果及时更新网络安全岗位设置和职责要求；
- c) 应定期审查授权审批记录，清理过期用户权限，发现问题要及时整改。

5.2.1.5 卓越级

应基于量化分析，统筹考虑网络安全机构和业务部门在职能设置、分工界面、力量投入等方面的平衡关系，保证安全需求在业务发展中有效落地，实现整体目标推进。

5.2.2 人力资源管理

5.2.2.1 初始级

应设立专职人力资源岗位，负责日常人力资源管理和人员聘用等相关工作。

5.2.2.2 控制级

本级要求包括：

- a) 应对拟录用人员的个人身份、学历背景、专业资质及能力等情况进行审核，并留存记录；
- b) 应在人员调岗、离职等程序中设置网络安全相关要求（如退还工卡、删除邮箱、回收系统账号等）。

5.2.2.3 规范级

本级要求包括：

- a) 应与在岗人员签订岗位责任协议，与关键岗位人员增加签订安全保密协议；
- b) 应制定安全背景和安全技能审查相关制度，对关键岗位人员进行安全审查；
- c) 应规范并严格执行人员聘用、调岗和离职程序，留存相关过程记录，涉及关键岗位人员变动的，及时通知相关部门，做好部门间协同；
- d) 应采用人员招聘、专家外聘、内部专项培养等多种形式结合，解决网络安全人员需求。

5.2.2.4 优化级

本级要求包括：

- a) 应根据行业发展趋势和组织内安全管理需求，持续优化人力资源变动流程；

- b) 应采取措施实现员工行为安全监测，及时发现人员在关键过程（如应聘、履职、调岗、离职等）中的常规性风险隐患。

5.2.2.5 卓越级

应采取技术措施实现员工行为安全的智能化监测与分析，及时发现人员在应聘、入职、履职、调岗、离职等关键过程中的隐蔽性风险隐患，并及时通报预警和联动处置。

5.2.3 教育培训及考核

5.2.3.1 初始级

应随机或者基于临时任务需要组织网络安全培训。

5.2.3.2 控制级

本级要求包括：

- a) 应安排专有人员负责组织开展网络安全教育及培训工作；
- b) 应能够主动对员工开展网络安全教育，提升网络安全意识；
- c) 应对培训过程实施管理，留存相关培训记录。

5.2.3.3 规范级

本级要求包括：

- a) 应制定网络安全教育培训相关制度，明确培训对象、培训内容、培训周期、培训时长等，具有规范化的培训记录表单；
- b) 应能够定期为不同角色人员提供按需培训，以及根据特殊需求提供定制化网络安全培训；
- c) 应建立网络安全考核及监督问责机制，明确考核指标、考核对象、问责目的、问责事项、问责措施等；
- d) 应建立正式的网络安全违规处理要求，明确违规事项、后果及处理流程，并向新入职员工及合作的第三方人员开展网络安全意识教育及违规风险宣传。

5.2.3.4 优化级

本级要求包括：

- a) 应制定系统化的网络安全人才培养体系，并将相关情况纳入绩效考核；
- b) 应制定激励机制，鼓励安全管理机构相关人员积极参与国家、行业或业界网络安全相关活动，获取新理念、新知识、新技能；
- c) 应建立知识库，实现网络安全相关知识、技能、经验的数字化、软件化管理，实现网络安全经验的积累和传播。

5.2.3.5 卓越级

本级要求包括：

- a) 应将团队人员安全专业能力进行抽象、凝练，形成自主判断、自动控制、自动编排的安全管理工具，将人员的分析、判断能力转化成智能的机器学习、分析判断及预测能力；
- b) 应系统梳理教育培训及考核实践经验，总结凝练并在行业内宣传推广。

5.2.4 沟通与合作

5.2.4.1 初始级

应基于具体任务对合作的第三方人员提出基础性工作要求。

5.2.4.2 控制级

本级要求包括：

- a) 与第三方合同中应覆盖网络安全要求；
- b) 应对合作的第三方人员开展网络安全意识宣贯。

5.2.4.3 规范级

本级要求包括：

- a) 应建立外部沟通与合作机制（同类业务运营者、行业专家、各类供应商、安全服务机构及安全组织等），且机制运行良好；
- b) 应制定并落实外部人员访问管理相关制度，明确外部人员到访受控区域、接入受控系统、离场等关键环节的安全管理要求，加强访问授权管理并形成记录表单，与获得访问权限的外部人员签订安全协议。

5.2.4.4 优化级

本级要求包括：

- a) 应积极参与国家、行业标准编制，以及国家、行业网络安全专项研究报告编制，促进网络安全先进经验沟通交流；
- b) 应强化技术交流合作，例如积极主办或承办国家、行业、业界网络安全相关活动。

5.2.4.5 卓越级

应加强国际合作，争取牵头或参与相关国际标准立项发布，或相关模式应用推广。

5.3 资产管理

5.3.1 资产清单管理

5.3.1.1 初始级

本级要求包括：

- a) 应采用临时或者非正式的方式记录资产信息；
- b) 应基于事件驱动，临时性确定部分资产的重要性等级。

5.3.1.2 控制级

本级要求包括：

- a) 应建立内部资产清单，记录资产类型、部署位置、责任人等信息，实施文档化管理；
- b) 应建立初步的资产分类分级原则，具有资产分类分级管理文档和记录表单，以人工方式处理资产的分类分级工作；
- c) 设立资产管理岗位，明确岗位的职责，岗位人员具备初步资产识别和信息收集管理能力。

5.3.1.3 规范级

本级要求包括：

- a) 应建立资产管理制度，明确资产清单管理、资产配置管理、管理角色和职责、资产管理策略等方面内容；

- b) 应建立资产管理清单，范围覆盖数据资产、应用系统资产、主机资产、终端资产、介质和外设资产、网络和安全设备资产以及备用资产；
- c) 应实时更新资产清单，并定期开展资产核查；
- d) 应梳理业务链，明确支撑业务运行相关的资产分布及运营、运维管理情况；
- e) 应实施资产分类分级管理，制定资产分类分级管理规定，明确资产分类分级原则，不同类别、不同重要等级资产的标识要求和安全管理要求。

5.3.1.4 优化级

本级要求包括：

- a) 应定期审查、更新资产管理制度，记录审核意见和变更日志；
- b) 应建立资产管理平台，覆盖资产的采购、入网、维护和报废全过程；
- c) 应建立动态的资产清单管理，覆盖互联网暴露面资产和内部在网资产，通过自动化资产测绘实现资产全量发现和属性数据自动采集，自动识别新增的非授权软硬件；
- d) 应将运营者建设、运营的电信网和互联网密切相关第三方资产纳入资产清单实施管理。

5.3.1.5 卓越级

本级要求包括：

- a) 应通过技术手段建立业务与资产的对应关系，自动发现业务链所依赖资产的变更以及资产安全风险等情况；
- b) 应建立自动化的资产标识能力，根据网络安全态势变化及业务需要，智能分析并调整资产安全等级。

5.3.2 资产日常管理和维护

5.3.2.1 初始级

本级要求包括：

- a) 应具有临时或者非正式的资产日常管理和维护要求；
- b) 应由事件驱动下的临时人员负责不同资产的日常管理；
- c) 应采取临时或者非正式的方式记录在用资产配置信息。

5.3.2.2 控制级

本级要求包括：

- a) 应对部分资产的日常管理和维护进行规范化管理，具有简单的管理文档和记录表单；
- b) 应设置不同资产的日常管理和维护岗位，岗位人员初步具备资产日常管理和维护能力；
- c) 应建立在用资产配置基线，用于在部署和恢复时配置资产，并确保同类资产采取相似的配置。

5.3.2.3 规范级

本级要求包括：

- a) 应制定全面的资产日常管理和维护规范，全面涵盖数据资产、应用系统资产、主机资产、终端资产、介质和外设以及网络和安全设备等资产；
- b) 应针对不同资产明确资产日常管理和维护的管理流程和配置管理指南，明确管理范围、实施组织和职责、操作和审批流程，包括但不限于资产入库、保管、使用、传输、维护、上线、监控、整改、应急处置、下线、销毁等；

- c) 应建立配置基线库，维护资产的基线配置并及时更新，并定期开展安全基线核查，确保资产配置与基线保持一致。

5.3.2.4 优化级

本级要求包括：

- a) 应定期审查和更新资产日常管理和维护规范、资产配置基线等，确保满足运营者网络安全目标；
- b) 应建立资产管理系统，自动化地开展资产配置检查，并具备配置基线恢复能力；
- c) 应建立资产管理平台与安全运营平台、运行监测平台等安全管理平台的关联，识别潜在的安全风险，并及时处置；
- d) 应定期开展资产利用率和使用情况核查，对于闲置资产按照下线或其他处置流程处理，并进行过程跟踪记录；
- e) 应规范资产下线过程，采取适当的网络安全技术手段进行数据脱敏或物理销毁。

5.3.2.5 卓越级

本级要求包括：

- a) 应根据网络安全态势变化及业务需要，智能分析并调整资产安全控制措施；
- b) 应根据资产管理平台与大数据平台、安全管理平台等关联情况，自动分析资产的闲置率，并及时提醒相关人员，对资产的回收和重复利用进行评估和处置。

5.3.3 资产变更管理

5.3.3.1 初始级

应采取临时或者非正式的方式记录资产变更情况。

5.3.3.2 控制级

本级要求包括：

- a) 应对资产变更实施之前，以某种方式评估其安全风险；
- b) 应详细记录变更过程，留存变更记录。

5.3.3.3 规范级

本级要求包括：

- a) 应在资产管理制度中明确资产变更管理要求，明确各类资产变更事项执行及审批流程，变更管理覆盖资产的部署、维护、下线等全生命周期；
- b) 应在资产变更前，制定变更计划，通过审批获得批准后方可按计划实施变更；
- c) 应在测试环境中验证通过后，实施资产变更部署，资产变更后，及时更新配置基线；
- d) 应对变更过程进行跟踪监控，识别变更过程中安全风险，并及时告警。

5.3.3.4 优化级

本级要求包括：

- a) 应在系统和软件首次部署或者重新上线部署前评估其安全性；
- b) 应采取技术手段实现自动化配置管理，自动识别如操作系统、应用程序版本和补丁级别版本号等信息，监测资产配置变化情况，防止未经授权的基线变更，实现自动纠正并告警；

- c) 应提供关键业务仿真验证环境，可在环境中进行系统和软件变更的测试和验证，包括变更失败恢复过程演练。

5.3.3.5 卓越级

应具备与业务管理、供应链安全风险管理协同联动的资产变更管理能力。

5.4 风险管理

5.4.1 风险控制

5.4.1.1 初始级

应以临时或者非正式的方式管理和记录网络安全风险。

5.4.1.2 控制级

本级要求包括：

- a) 应指定专门团队或人员负责组织开展网络安全风险管理工作；
- b) 应根据业务运行情况，对安全风险进行优先级排序。

5.4.1.3 规范级

本级要求包括：

- a) 应建立网络安全风险管理工作机制，明确风险管理覆盖的内容和流程等；
- b) 应由网络安全管理部门与业务运营、运维等安全相关部门的人员共同参与风险管理工作；
- c) 应根据业务情况，确定风险承受度及风险优先级判定方法。

5.4.1.4 优化级

应持续更新风险管理工作机制，与业务发展目标、网络安全战略保持一致。

5.4.2 风险识别和防范

5.4.2.1 初始级

应采取临时或者非正式的风险应对措施，包括识别风险、规避风险、接受风险、降低风险和分担风险。

5.4.2.2 控制级

应根据网络安全风险管理需要，初步建立资产脆弱性列表及安全威胁列表。

5.4.2.3 规范级

本级要求包括：

- a) 应制定风险管理方案，建立风险评估、风险监控、风险规避等相关流程和实施细则；
- b) 应基于资产清单，从技术和管理两方面，系统性识别网络和系统的安全风险，内部资产的脆弱性，形成脆弱性列表；
- c) 应识别来自人员、环境及其他方面的安全威胁，形成威胁列表，并进一步分析威胁来源、动机及发生频率等，依据威胁影响程度对威胁划分等级；
- d) 应依据风险影响程度、风险承受能力和风险响应能力，对威胁和脆弱性进行评估、分类和优先排序。

5.4.2.4 优化级

本级要求包括：

- a) 应定期维护脆弱性列表及安全威胁列表，并根据符合性评测、风险评估、安全检查等结果动态更新风险列表及优先级；
- b) 应定期审阅风险控制措施的有效性，以确定网络安全风险是否得到缓解；
- c) 应持续跟踪安全威胁列表中的中高级网络安全风险，并及时采取风险应对措施；
- d) 应将风险识别的范围延伸到与业务运行紧密关联的外部组织、网络、系统的安全风险。

5.4.2.5 卓越级

应持续关注国内外最新的风险管理的方法论、监测和研判方法、应对和处置措施，持续提升风险的监测实时性、研判准确性、处置有效性。

5.5 供应链安全管理

5.5.1 供应链安全风险管理

5.5.1.1 初始级

应以临时或者非正式的方式管理产品、技术、服务供应商的相关情况。

5.5.1.2 控制级

本级要求包括：

- a) 应建立供应商列表，包括供应商名称，提供的产品或服务，负责人及联系方式、服务周期性等内容；
- b) 应在执行网络产品和服务采购过程中，将供应链安全风险纳入考虑；
- c) 应根据专业知识、历史合作记录等预先验证供应商资格。

5.5.1.3 规范级

本级要求包括：

- a) 应建立供应链安全管理策略，说明供应链安全管理的总体目标、范围、原则等；
- b) 应将已识别的供应链安全风险纳入风险管理；
- c) 应持续监测供应商在提供产品和服务等过程中的安全风险，跟踪记录由于供应商和其他依赖关系造成的重大网络安全风险及其解决情况；
- d) 应识别供应链安全依赖关系，重点关注单一来源及其他具有重要依赖关系的供应商的安全风险；
- e) 应建立合格供应商目录，尽可能实现相同产品、服务的供应商多元化，以防范供应商出现因政治、外交、贸易等非技术因素导致产品和服务供应中断的风险。

5.5.1.4 优化级

应持续跟踪供应商及其产品和服务的相关情况，包括但不限于组织机构变化、股权变更、外交政策影响、经济形势影响、上下游变更、安全事件披露，以及其产品和服务的安全风险。

5.5.1.5 卓越级

应联合行业其他主体建立供应链安全信息共享机制。

5.5.2 采购情况管理

5.5.2.1 初始级

应基于临时任务需要，对采购过程实施安全管理。

5.5.2.2 控制级

应与供应商协商并明确网络安全要求。

5.5.2.3 规范级

本级要求包括：

- a) 应管理采购清单，记录内容包括但不限于名称、类别、用途、供应商、部署位置等信息；
- b) 应与供应商签订安全协议，协议内容包括但不限于服务内容、安全责任、违约责任以及处罚条款等；
- c) 应对安全服务机构实施目录管理，选择具有信息通信网络安全服务能力认证资质的机构提供安全服务；
- d) 应制定并实施适用于供应商管理的网络安全基线，明确供应商必须满足的产品和服务安全标准；
- e) 采购资产的验收测试应包括网络安全测试，并出具报告；
- f) 对供应商和其他外部实体的选择和评估，应将其网络安全能力作为重要考虑因素；
- g) 在与供应商签订的协议中，应明确要求当其交付的产品或服务涉及网络安全漏洞、网络安全事件时，及时通知并采取处置措施；
- h) 应在产品采购和提供服务的过程中，确需获取内部访问权限的供应商，确保其获得访问授权期间，采取必要的安全控制措施。

5.5.2.4 优化级

应定期开展供应商安全审核，确保其具备持续满足网络安全要求的能力。

5.5.2.5 卓越级

梳理采购过程中存在的单一来源、产能受限等问题，开展相关研究，为行业增强供应链安全提供依据。

5.6 系统和通信防护

5.6.1 身份管理

5.6.1.1 初始级

应为访问部分资产（包括但不限于数据、信息系统、软件、硬件、设备机房等）的人员以及设备、应用等其他实体建立临时、非正式或者共享的身份账号。

5.6.1.2 控制级

本级要求包括：

- a) 应为需要访问资产的人员以及设备、应用等其他实体设置身份账号，对涉及重要操作的人员颁发访问凭据(如智能卡、证书、密钥等)；
- b) 应及时取消过期或者无效身份账号，回收访问凭据；

- c) 应指定专门的部门或人员进行账户管理。

5.6.1.3 规范级

本级要求包括：

- a) 应建立账号管理平台，实现对组织内部账号的统一管理；
- b) 应具有建立账户申请、建立、删除的审批流程，划分不同管理员角色；
- c) 应用系统访问应采用多因素身份鉴别方式等；
- d) 应采取技术手段保护用户远程访问的身份鉴别信息安全；
- e) 应定期审查和更新账号管理平台，确保账号有效性；
- f) 应定期审查访问凭证，以确保它们与正确的人员或实体相关联。

5.6.1.4 优化级

本级要求包括：

- a) 应用系统访问应采用动态的身份鉴别方式，针对关键行为采用可信数字证书等多因素认证的方式进行身份认证；
- b) 应基于不同的业务场景，明确不同识别身份认证的需求，建立分场景、细粒度身份认证方案。

5.6.1.5 卓越级

应研究并利用区块链、分布式标识等新技术，提升身份认证管理安全性。

5.6.2 访问控制

5.6.2.1 初始级

应以临时或者非正式的方式实施访问控制，设置访问控制策略。

5.6.2.2 控制级

本级要求包括：

- a) 应设置访问控制策略，明确被授权主体可访问的资产类型、范围及访问限制条件；
- b) 应根据需要对访问主体授予访问权限；
- c) 应动态监测越权访问行为，一旦发现自动禁止，并及时告警。

5.6.2.3 规范级

本级要求包括：

- a) 应建立各类资产的访问控制策略及其授权审批程序，并根据访问控制策略设置访问控制规则；
- b) 应授权遵循最小特权原则，仅开放必要的业务端口、协议、系统功能和服务，仅安装必要的组件和应用程序，关闭不需要的、默认共享和高危端口，并定期审查；
- c) 应落实职责分离原则，明确网络安全相关各岗位职责、权限和风险，分离相冲突的工作职责，包括但不限于技术与业务分离、授权与审计分离、开发与操作分离；
- d) 当发现未授权设备（移动硬盘、U 盘等），通过各种方式接入网络时，应及时阻断并发出预警
- e) 访问请求应获得包括资产所有者在内的授权；
- f) 应采取技术措施，实现控制和监视安装的软件，限制、禁用不必要的程序、端口、功能、协议和服务。

5.6.2.4 优化级

本级要求包括：

- a) 应采取 4A 集中管理等技术措施实现统一的账号、授权、认证和审计管理；
- b) 应对关键或敏感的资产和操作采用双重授权，由被授权主体联合执行特权操作；
- c) 应实施自动化的安全策略配置以及动态访问控制；
- d) 应定期对访问权限进行审查和更新，以确保有效性；
- e) 应根据业务场景需要，实现人员、设备、时间等多要素关联的精细化、差异化访问授权；
- f) 应对超级权限、管理权限、紧急访问权限以及共享账号等的使用情况进行监控；
- g) 重要应用系统应开启登录用户 IP 地址限制，重要操作应使用特定资源进行访问。

5.6.2.5 卓越级

本级要求包括：

- a) 应与网络安全态势感知等安全管理系统联动，根据网络态势变化自动更新访问控制策略；
- b) 应利用人工智能、大数据、区块链等先进技术，建立全生命周期访问控制和追溯机制。

5.6.3 系统和边界防护

5.6.3.1 初始级

应划分不同的网络区域，在重要网络区域与其他网络区域之间采取安全隔离技术手段。

5.6.3.2 控制级

本级要求包括：

- a) 应指定专门的团队或人员负责系统安全防护，并明确具体的工作职责；
- b) 应建立网络区域划分原则，并依据原则划分网络区域；
- c) 应采取必要的措施控制跨越安全边界的访问和数据传输；
- d) 应在网络中部署相关系统或组件对网络攻击行为、恶意代码等进行检测和分析。

5.6.3.3 规范级

本级要求包括：

- a) 应建立系统运维相关管理制度，对系统相关的安全策略、账号管理、日志管理、日常操作、升级与打补丁、口令更新周期等方面做出规定；
- b) 应实施分区分域、分层防护的网络管理，合理划分安全域，在日常办公、业务运营、管理支撑等不同网络间采取物理或逻辑隔离措施，在网络边界或区域之间实施访问控制，保证跨越边界的访问和数据流通过边界防护设备提供的受控接口进行通信；
- c) 应采取入侵防护措施防范来自内外部的恶意网络攻击，监测并清洗异常网络流量。

5.6.3.4 优化级

本级要求包括：

- a) 虚拟化技术的基础设施宜采用 SDP、微隔离等技术措施，实现不同服务对象虚拟网络之间及同一服务对象不同虚拟网络之间的隔离；
- b) 应对重要数据传输采用专用通信协议或安全通信协议，避免来自基于通用通信协议的攻击破坏数据完整性、保密性；
- c) 应采取服务伪装、欺骗防御、蜜网构建等技术措施，实现网络威胁诱捕，主动获取攻击身份、手段和过程等情报信息；
- d) 应部署大规模拒绝服务攻击防护，通过清洗攻击流量，保障业务可用性。

5.6.3.5 卓越级

应具备对流量的深度分析能力，及时发现潜在安全威胁，并采取自动化的处置措施。

5.7 运行维护

5.7.1 安全运维

5.7.1.1 初始级

应以临时或者非正式的方式，开展网络和系统维护工作。

5.7.1.2 控制级

本级要求包括：

- a) 应建立基本的运行维护实施过程管理要求；
- b) 应指派专门的部门或人员负责系统运行维护管理相关工作；
- c) 应记录运维操作日志，包括日常巡检工作、运行维护记录、参数的设置和修改等内容。

5.7.1.3 规范级

本级要求包括：

- a) 应制定体系化的运维管理制度，包括但不限于运维人员职责、工作流程、维修过程管理等；
- b) 应规范外包运维服务方及相关人员的管理（例如涉及系统操作，应急保障，以及敏感信息的访问、处理与存储等）；

5.7.1.4 优化级

本级要求包括：

- a) 应定期审查和更新运维管理要求和 workflows，确保满足运营者业务安全目标；
- b) 应设置运行维护过程度量指标，对运行维护过程实施定量控制，有效控制运维工作实施效果。

5.7.1.5 卓越级

应建立覆盖监控、告警、处置等全流程的、自动化的运维体系。

5.7.2 状态监控

5.7.2.1 初始级

本级要求包括：

- a) 应以临时或者非正式的方式，开展网络安全监控，如监控网络状态、记录网络安全日志等；
- b) 应记录监控发现的网络安全异常状态。

5.7.2.2 控制级

本级要求包括：

- a) 应对高风险资产实施安全状态监控；
- b) 应指派专门的部门或人员负责网络及系统安全状态监控相关工作。

5.7.2.3 规范级

本级要求包括：

- a) 应建立定期巡检机制，明确巡检内容、范围、人员、频次等相关事项，并留存相关巡检记录，巡检内容包括但不限于机房场地、设备的物理安全状态，及时发现断电、报警等问题；
- b) 应建立实时监控机制，持续监测网络基础设施运行状况；
- c) 应明确监控和分析要求，细化监控对象和监控内容；
- d) 应建立系统日志、数据流、系统状态等网络安全异常指标。

5.7.2.4 优化级

本级要求包括：

- a) 应根据网络安全态势变化，持续调整网络安全监控要求，更新异常指标列表；
- b) 应自动监测网络和系统安全，自动识别异常活动。

5.7.2.5 卓越级

应根据网络和系统安全状态，采取智能化安全应对措施。

5.7.3 日志及审计

5.7.3.1 初始级

应以临时或者非正式的方式，记录重要资产的日志信息。

5.7.3.2 控制级

本级要求包括：

- a) 应至少以临时方式开展日志审计（如审查运行日志、操作日志等）；
- b) 应记录各类违规访问日志，并留存6个月以上。

5.7.3.3 规范级

本级要求包括：

- a) 应明确日志管理要求，包括但不限于记录日志类型，以及日志采集、保存、备份、审计等的相关要求；
- b) 日志内容涉及重要数据和个人敏感信息的，应采取适当的保护措施；
- c) 应明确各类日志的存储位置、存储方式、访问权限及留存周期；
- d) 应定期开展日志审计，对系统日志、操作日志等进行分析和异常检测，如发现未授权、可疑或异常活动及时报警，并落实整改、留存相关记录；
- e) 应实施日志关联性分析，明确采集、汇总、处理等相关流程要求。

5.7.3.4 优化级

本级要求包括：

- a) 应定期通过专用系统或其他自动化技术措施，执行日志审计分析；
- b) 应基于安全态势变化，定期更新日志监控策略和管理要求；
- c) 应开展智能化的日志关联性分析，自动采集部署在各地的软硬件日志数据；
- d) 应实现对用户行为的自动化审计，并具备追溯能力。

5.7.3.5 卓越级

应持续优化日志审计工作机制，实现主体、资源、行为全覆盖，依托量化指标体系加强审计效果，持续开展审计跟踪和追溯。

5.7.4 备份和恢复

5.7.4.1 初始级

本级要求包括：

- a) 在发生网络事件或事故时，应至少以临时方式维持和恢复系统和网络主要功能；
- b) 应确保重要通信线路、关键网络设备的硬件冗余；
- c) 应对重要数据进行备份。

5.7.4.2 控制级

本级要求包括：

- a) 应确保网络、系统和资产备份的可用性，并经过验证；
- b) 应指定专门的部门或人员负责备份设备、线路、数据的定期维护。

5.7.4.3 规范级

本级要求包括：

- a) 应建立灾难备份管理工作机制，包括总体目标、体系建设（例如冗余配置、灾备中心建设等）、备份机制、备份和恢复方案等；
- b) 应明确恢复时间目标和恢复点目标等有关要求，定期审查和更新备份和恢复方案的有效性，确认备份、恢复情况是否与恢复目标保持一致；
- c) 应识别保障业务运行的基本业务功能，对支撑其运行的网络、系统、设备等进行冗余配置，并制定备份恢复计划；
- d) 应识别需要定期备份的重要业务信息、设备配置、系统数据及软件系统等，确定备份方式、备份频度、存储介质、保存期、责任人、存放位置等；
- e) 备份和恢复方案应通过应急演练、桌面推演等评估和演练；
- f) 重要数据、业务系统应实现异地备份。

5.7.4.4 优化级

本级要求包括：

- a) 应识别所依赖的其他外部业务和其他信息通信网络单元，以及其对于网络和系统运行和提供服务的重要性，将其纳入影响业务连续性的相关因素考虑；
- b) 应全面梳理网络和系统的业务情况，包括但不限于系统功能、服务内容、服务对象、业务信息类型、业务规模，以及服务中断的影响范围、影响程度及服务可替代性，并在备份和恢复方案中予以明确。

5.7.4.5 卓越级

本级要求包括：

- a) 应探索研究运营者内外部多源、业务连续不中断以及特殊极端场景等不同情况下的备份恢复方案；
- b) 应持续跟踪研究国内外备份和恢复的优秀解决方案，在具备条件时吸收采纳并用于备份和恢复工作优化改进。

5.8 检测评估

5.8.1.1 初始级

本级要求包括：

- a) 应以临时或者非正式的方式组织网络安全检测及风险评估活动，包括但不限于组织符合性评测、风险评估、数据安全评估、密码安全评估，开展恶意代码扫描、渗透性测试、资产漏洞扫描，以及其他发现异常、可疑、恶意的活动等；
- b) 应根据经验，选择性处理检测评估活动中发现的安全漏洞和威胁。

5.8.1.2 控制级

本级要求包括：

- a) 应定期自行或委托具有资质的第三方网络安全服务机构开展符合性测评，内容包括但不限于安全管理制度执行情况、组织机构建设情况、安全基线检查等；
- b) 应定期或者根据需要，针对信息通信网络单元开展网络安全风险评估，包括但不限于系统上线或发生重大变更、重大活动保障等；
- c) 应开展上线前安全检测，包括操作系统和数据库管理安全检测、安全漏洞扫描、安全基线检查、源代码审计、APP 安全检测等；
- d) 应配备专门的部门或者人员负责定期组织开展恶意代码扫描、渗透性测试、资产漏洞扫描，以及其他发现异常、可疑、恶意的活动等；
- e) 应对检测评估活动中发现的网络安全漏洞、隐患，评估严重程度和影响范围，并优先处理高级别的安全问题。

5.8.1.3 规范级

本级要求包括：

- a) 应明确体系化的安全检测评估工作要求，规范检查对象、检测方法、检测流程、检测周期、检测人员组织及职责、资金保障等相关内容；
- b) 根据检测评估结果和安全整改建议，及时组织整改实施，持续跟进整改情况，并验证整改结果的有效性，留存整改过程加固记录。

5.8.1.4 优化级

本级要求包括：

- a) 应定期组织审定检测评估工作方案，持续完善检测评估工具、方法和策略，并根据检测情况和检查重点持续改进检测流程、检测方法等；
- b) 应开展常态化、自动化的安全检测和风险评估。

5.8.1.5 卓越级

应具备智能化分析和评估网络安全风险，动态、自适应地预测、检测，并自动采取风险缓解措施的能力。

5.9 安全态势分析

5.9.1 漏洞管理

5.9.1.1 初始级

本级要求包括：

- a) 临时或者基于任务需要扫描网络系统和应用程序中的漏洞，应采取相应的处理措施，使其得到临时性缓解；

- b) 应以临时或者非正式的方式，记录网络安全漏洞信息。

5.9.1.2 控制级

本级要求包括：

- a) 应定期扫描网络系统和应用程序中的漏洞，发现安全漏洞后，能够及时修补或采取其他有效措施予以处理；
- b) 应有相关的岗位或人员，负责管理网络产品和系统漏洞情况，维护漏洞清单记录，指导监督采取缓解措施；
- c) 发现或者获知内部资产存在安全漏洞后，应立即采取措施，及时对安全漏洞进行验证并完成修补。

5.9.1.3 规范级

本级要求包括：

- a) 应建立漏洞管理要求，形成漏洞发现、预警、验证、修复加固等网络漏洞闭环管理，实现漏洞发现、报告、修补全程跟踪；
- b) 应识别支撑漏洞发布的信息源，如漏洞信息共享平台、产品厂商等，监测信息源中与资产相关的漏洞信息；
- c) 应定期进行主机系统、数据库系统、中间件及应用系统漏洞检测，更新漏洞清单，并及时对漏洞进行修补；
- d) 应建立内部漏洞信息共享机制，确保运营者内部相关人员及时获知已知漏洞信息。

5.9.1.4 优化级

本级要求包括：

- a) 应建立网络产品安全漏洞信息接收渠道并保持畅通，持续跟踪资产漏洞情况，发现或者获知内部资产存在安全漏洞后，立即采取措施，及时对安全漏洞进行验证并完成修补；
- b) 应将网络安全漏洞处置情况，纳入持续风险监测，确保处置措施的有效性；
- c) 应采取技术措施实现资产漏洞管理，实现资产异常及脆弱性自动检测、预警与安全防护；
- d) 应实现对网内资产和漏洞信息进行统一关联、展示和告警。

5.9.1.5 卓越级

本级要求包括：

- a) 应汇聚产学研用多方力量组建专业队伍，具备独立评估安全漏洞的能力；
- b) 应积极参与国家、行业漏洞信息共享与预警机制建设；
- c) 应具备零日漏洞的收集、发现及修补能力。

5.9.2 威胁信息管理

5.9.2.1 初始级

应以临时或者非正式的方式管理网络安全威胁信息。

5.9.2.2 控制级

本级要求包括：

- a) 应有相关的岗位或人员，负责跟踪网络安全威胁情况，指导监督采取缓解措施；

- b) 应对已识别的威胁进行分析和优先级排序，形成特定的解决方案应对网络安全威胁，如采取监控和缓解措施等。

5.9.2.3 规范级

本级要求包括：

- a) 应根据内部业务、资产、网络等相关情况，面向有关部门或责任人提供网络安全威胁信息；
- b) 应建立安全威胁信息库，威胁信息来源包括对内外部的网络和系统的持续监测、检测评估及网络安全事件跟踪等，并持续收集恶意代码、网络攻击、网络安全事件等最新动向，动态更新网络安全威胁信息库。

5.9.2.4 优化级

本级要求包括：

- a) 应建立外部信息共享机制，具有三种及以上的网络安全威胁外部信息来源，包括但不限于保护工作部门、同类业务运营者、行业专家、安全服务机构、供应链上下游以及其他外部数据源；
- b) 应将威胁情报信息用于运营者网络和系统的安全架构设计与建设、安全解决方案选择、安全事件应急处置等。

5.9.2.5 卓越级

本级要求包括：

- a) 应建立自动化流程或者其他技术手段，自动推送网络安全威胁信息和应对措施；
- b) 应智能化开展网络安全威胁研判，自动匹配相关的资产和影响范围，实施自动化安全处置措施。

5.9.3 态势感知

5.9.3.1 初始级

应初步具备收集并记录部分或全部关于威胁、漏洞、终端等网络安全态势的能力。

5.9.3.2 控制级

应初步具备业务系统监控数据、网络安全日志等数据收集和汇聚能力，为网络安全态势分析提供基础数据。

5.9.3.3 规范级

本级要求包括：

- a) 应具备汇总业务系统监控数据、网络安全日志、安全漏洞数据库、恶意代码库等各类数据，初步形成网络安全态势分析的能力；
- b) 应建设安全管理相关技术手段，实现网络状态、网络攻击、安全事件等的实时监测能力，及时发现网络安全风险隐患，并判断风险等级；
- c) 应建立威胁检测及分析研判能力，识别、分析、评估网络安全状态，及时发现网络安全风险隐患。

5.9.3.4 优化级

本级要求包括：

- a) 应建立具有可视化功能的统一安全管理中心，实现全网资产、安全漏洞、风险隐患、安全事件等的接入与分析；
- b) 应基于持续监测及威胁情报信息收集结果，识别、分析、评估网络安全状态变化趋势，预测网络安全态势发展，提供网络安全事件预警；
- c) 应具备已知威胁的感知能力，能够检测外部渗透、数据窃取等高级别安全威胁；
- d) 应定期形成网络安全态势报告，将网络安全态势信息用于安全规划、架构设计与建设、安全解决方案选择、安全事件应急处置等。

5.9.3.5 卓越级

本级要求包括：

- a) 应基于网络安全态势分析，具备智能化主动式威胁感知和处置能力，发现并自动采取风险缓解措施；
- b) 应持续优化威胁风险规则和模型的技术和算法，实现常见威胁风险的实时监测感知；
- c) 应建立发现未知安全风险检测和高级持续性威胁发现的能力。

5.10 网络安全事件管理

5.10.1 事件响应和处置

5.10.1.1 初始级

本级要求包括：

- a) 应指派临时团队或者人员负责网络安全事件处置；
- b) 应基于事件驱动，以临时方式应对网络安全事件；
- c) 应采取临时或者非正式的方式，记录网络安全事件。

5.10.1.2 控制级

本级要求包括：

- a) 应指派专门的团队或者人员负责网络安全事件响应处置，并分配职责角色；
- b) 应具有针对部分业务系统或者部分网络安全事件的应急响应和处置流程；
- c) 应规范实施网络安全事件记录管理。

5.10.1.3 规范级

本级要求包括：

- a) 应建设体系化的网络安全事件应急体系，明确角色与职责、明确事件分类分级原则、应急响应流程、应急处置措施等，覆盖事件全生命周期安全管理（例如，上报、处理、沟通、协调和关闭）；
- b) 应针对不同分类分级安全事件的应急响应流程进行具体说明；
- c) 应建立网络安全事件应急响应和处置平台，能够对网络安全事件进行统筹管理、分类分级、指挥调度、策略分发、事件上报等，并支持对部分安全事件进行及时处置等；
- d) 应为网络安全事件响应处置提供充足的人员、资金和资源支持；
- e) 应建立网络安全事件知识库，总结凝练网络安全事件响应处置经验。

5.10.1.4 优化级

本级要求包括：

- a) 应定期审阅并调整网络安全应急体系，根据发生的安全事件定向调整网络安全控制措施、网络安全事件应急处置流程；
- b) 应急响应和处置平台应具备安全编排自动化响应能力，可以实现安全事件快速响应处置；
- c) 应分析总结网络安全事件根本原因、事件响应和处置的有效性，持续完善知识库，调整事件响应计划；
- d) 应强化外部合作，建立与行业主管、监管部门网络安全事件处置机制协同联动。

5.10.1.5 卓越级

本级要求包括：

- a) 应急响应和处置平台应具备与大数据平台、安全运维平台等的联动编排能力，实施智能化事件处置；
- b) 应针对已知类型攻击事件，能够追踪溯源，还原攻击路径，具备安全事件反制能力；
- c) 应积极在业界分享最佳事件响应和处置实践，打造行业标杆。

5.10.2 应急演练

5.10.2.1 初始级

应根据临时任务或其他需要，组织开展应急演练。

5.10.2.2 控制级

本级要求包括：

- a) 应有专门的团队或人员负责组织网络安全应急演练；
- b) 应针对重要事件制定应急预案。

5.10.2.3 规范级

本级要求包括：

- a) 应系统规划网络安全的应急演练工作方案，包括但不限于制定应急预案、组织应急演练、加强宣传培训等；
- b) 应定期（至少每年一次）组织内部相关人员进行应急响应培训和应急演练，使其掌握岗位职责和应急处置策略和规程，并留存相关记录。

5.10.2.4 优化级

本级要求包括：

- a) 应基于应急演练结果，测试、评估应急预案，并实现持续更新和优化；
- b) 应组织和参与不同形式、不同场景的应急演练，整改反馈问题，持续优化应急预案；
- c) 应建立与企业业务和网络相关的攻防仿真环境。

5.10.2.5 卓越级

应积极组织或联合其他实体共同开展网络安全演习（如桌面推演、攻防演练）。

参 考 文 献

- [1] GB/T 20261-2006 信息技术 系统安全工程 能力成熟度模型
 - [2] GB/T 30271-2013 信息安全技术 信息安全服务能力评估准则
 - [3] GB/T 36073-2018 数据管理能力成熟度评估模型
 - [4] GB/T 37988-2019 数据安全能力成熟度模型
 - [5] GB/T 39116-2020 智能制造能力成熟度模型
 - [6] Carnegie Mellon University and The Johns Hopkins University Applied Physics Laboratory LLC. Cybersecurity Maturity Model Certification.2020
 - [7] Office of Cybersecurity, Energy Security, and Emergency Response. Cybersecurity Capability Maturity Model.2021
-